succeeded, otherwise you shouldn’t trust the certificate.

If the client had directly connected to the Java API server, then the certificate is available through a request attribute:

```
var cert = (X509Certificate) request.attributes(
        "javax.servlet.request.X509Certificate");
```

You can reuse the `decodeCert` method from the `UserController` to decode the certificate from the header and then compare the hash from the confirmation key to the certificate thumbprint using the `MessageDigest.isEqual` method. Open the OAuth2TokenStore.java file and update the `processResponse` method to enforce certificate-bound access tokens as shown in listing 11.9.

Listing 11.9 Verifying a certificate-bound access token

```
private Optional<Token> processResponse(JSONObject response,
        Request originalRequest) {
    var expiry =
Instant.ofEpochSecond(response.getLong("exp"));
    var subject = response.getString("sub");

    var confirmationKey = response.optJSONObject("cnf");
#A
    if (confirmationKey != null) {
        for (var method : confirmationKey.keySet()) {    #B
            if (!"x5t#S256".equals(method)) {    #C
                throw new RuntimeException(    #C
```